

Guía de operación, costos y escalamiento

Aether ERP (Next.js 16 en Vercel, PostgreSQL en Neon, Cloudflare delante y R2 para archivos).
Qué pagar, cuándo, y qué mantener para que el sistema no se caiga.

Importante sobre las cifras. Los costos son **estimaciones** hechas con las tarifas de Neon que muestra tu pantalla de planes (\$0,106 por CU-hora y \$0,35 por GB-mes en Launch) y con los precios públicos que conozco de Vercel y Cloudflare. No medí tu consumo real. Los precios y límites cambian: confirma cada uno en el panel del proveedor antes de decidir. Todo está en dólares (USD) por mes.

1. Resumen

- **Hoy no hay nada que te impida operar con 10 empresas** si pagas Vercel Pro y Neon Launch. Con 50 empresas, el sistema alcanza en capacidad; lo que más se parece a un riesgo son los picos de eventos (votación y entradas) y las tareas pesadas, no la cantidad de empresas.
- **Gasto mensual esperado:** unos \$30 a \$55 con 10 empresas y unos \$75 a \$155 con 50 empresas (el extremo alto incluye opcionales como Cloudflare Pro y Sentry de pago).
- **Vercel Pro es obligatorio desde el primer cliente que pague:** el plan Hobby no permite uso comercial y el proyecto usa 13 tareas programadas (cron) que ese plan no admite.
- **Neon Launch conviene antes de tener datos que no puedas perder** (respaldo y restauración más largos, cómputo siempre disponible).
- **Lo que más te protege no cuesta dinero:** ramas de Neon separadas para desarrollo, alertas de uso, un monitor externo de disponibilidad, Sentry y probar la restauración de respaldos.

2. Cuánto pagar

Escenarios mensuales (USD). Las columnas son rangos, no promesas.

Servicio	Qué cubre	10 empresas	25 empresas	50 empresas
Vercel Pro	Hosting, funciones, 13 cron, firewall. \$20 por usuario con acceso al panel.	\$20	\$20	\$20 (más si superas el uso incluido)
Neon Launch	PostgreSQL. \$0,106/CU-hora + \$0,35/GB-mes.	\$10 a \$20	\$20 a \$35	\$40 a \$60
Cloudflare (proxy, WAF, Turnstile)	Plan Free. Pro (~\$25) solo si necesitas más reglas de WAF o bots.	\$0	\$0	\$0 a \$25
Cloudflare R2	Fotos, logos, contratos, certificados. Plan gratis mensual y luego por GB; sin cobro por salida.	\$0	\$0 a \$1	\$1 a \$3
Gemini API (agentes)	Solo si activas el equipo ejecutivo virtual. Tarifa por uso.	\$0 a \$5	\$2 a \$10	\$5 a \$20
Correo transaccional	Confirmaciones, boletas, recordatorios. Depende del proveedor SMTP.	\$0 a \$10	\$0 a \$15	\$10 a \$25
Dominio	Dominio propio (anual, prorrateado).	\$1	\$1	\$1
Sentry (opcional)	Errores en producción. El plan gratis suele bastar al inicio.	\$0	\$0	\$0 a \$26
Total aproximado		\$30 a \$55	\$45 a \$80	\$75 a \$155

Cómo se calcula Neon. Una CU-hora es una unidad de cómputo funcionando una hora. Ejemplo: cómputo mínimo de 0,25 CU encendido las 24 horas = 183 CU-horas x \$0,106 = \$19,3, más 3 GB de datos x \$0,35 = \$1. Total: unos \$20. Con un

promedio de 0,5 CU las 24 horas son unos \$40. Los picos (hasta 16 CU) solo cobran las horas que duran.

Cuándo se paga cada cosa

Servicio	Cuándo dar el salto	Por qué
Vercel Pro	Antes del primer cliente que pague.	Hobby es solo personal/no comercial y limita los cron a pocas tareas diarias.
Neon Launch	Antes de guardar datos contables o tributarios que no puedas perder; o al acercarte a 1 GB o a las 100 CU-horas gratis.	Free se suspende por inactividad y la ventana de restauración es corta.
Neon Scale	Si un cliente exige SOC 2/HIPAA, IP allow, redes privadas o un SLA de 99,95 %; o si necesitas más de 16 CU sostenidos.	Cuesta más del doble por CU-hora. Con 10 a 50 empresas no se justifica.
Cloudflare Pro	Si el WAF gratuito se queda corto, o si quieres Super Bot Fight Mode.	El plan Free cubre proxy, TLS, Turnstile y las reglas básicas.
R2	Ya conviene configurarlo: reemplaza a Vercel Blob y no cobra salida de datos.	Tiene más almacenamiento por menos dinero. Hoy el código cae a Vercel Blob si no está configurado.

3. Lo que debes tener para que no se caiga

Está ordenado por importancia. Lo marcado como "Hecho en el código" ya existe en el repositorio; lo demás se configura en paneles.

3.1 Base de datos (Neon)

- **Rama de desarrollo separada.** Hoy el `.env` local apunta a la MISMA base que producción: cualquier migración o script de prueba afecta a clientes reales. Crea una rama de Neon para desarrollo y otra para pruebas, y usa una URL distinta en cada lugar.
- **Cadena pooled.** `DATABASE_URL` debe usar el host con `-pooler`. El código ya limita a 5 conexiones por instancia (Hecho en el código), pero eso solo sirve si la URL es la del pooler.
- **Migraciones aditivas e idempotentes** (Hecho en el código: hay un test que lo exige). Nunca borres columnas ni agregues `NOT NULL` sobre tablas con datos sin un plan.
- **Restauración probada.** Confirma la ventana de restauración de tu plan y ensaya al menos una vez restaurar a una rama nueva. Un respaldo que nunca se probó no es un respaldo.
- **Alertas de uso y de gasto** en Neon (cómputo, almacenamiento, conexiones).
- **Consultas lentas.** Revisa cada mes la lista de consultas lentas de Neon; son el primer síntoma antes de que algo se caiga.

3.2 Aplicación (Vercel)

- **Variables de entorno completas en Production:** `DATABASE_URL`, `SESSION/JWT secrets`, `CRON_SECRET`, `CLOUDFLARE_ORIGIN_SECRET`, `TURNSTILE_*`, `R2_*`, `R2_PRIVATE_BUCKET_NAME`, `SENTRY_DSN`, claves de Khipu/ZapSign si se usan.
- **Rollback rápido.** Aprende a usar "Instant Rollback" en Vercel: si un despliegue sale mal, vuelves a la versión anterior en segundos. Las migraciones se aplican en el build, así que una migración fallida deja viva la versión anterior (Hecho en el código).
- **Despliegues de prueba (Preview)** contra la rama de desarrollo de Neon, nunca contra producción.
- **Alertas de Vercel** por errores y uso, y revisión mensual de funciones lentas o con más consumo.
- **Tareas programadas (13 cron).** Verifica cada mes en el panel que se ejecutaron. Todas exigen `CRON_SECRET` (Hecho en el código). Si una falla en silencio, nadie lo nota hasta que falta la alerta de folios del SII o el cierre mensual.
- **Tiempos máximos.** Backup completo: 300 s; afiches: 60 s. Una empresa muy grande puede superar el tiempo del backup; pruébalo con la empresa más grande.

3.3 Cloudflare y seguridad

- **Conectar Cloudflare de verdad:** el código está listo, pero se activa solo con `CLOUDFLARE_ORIGIN_SECRET`, Turnstile y la configuración del panel. Sigue `docs/security/cloudflare.md` paso a paso (DNS con proxy, SSL Full strict, WAF, límites de peticiones).
- **Bloqueo de origen.** Sin la regla de firewall de Vercel, alguien puede saltarse Cloudflare entrando directo a `*.vercel.app`. Actívala en modo Log primero.
- **Límite de peticiones en el borde.** El limitador de la app es por instancia (no comparte contadores entre instancias). Cloudflare cubre ese hueco.
- **Bucket privado de R2 (nuevo, ver sección 5).** Con él, el certificado médico deja de tener URL pública.
- **No activar Bot Fight Mode:** bloquea a Vercel Cron, Khipu, ZapSign y n8n.

3.4 Observabilidad y monitoreo

- **Sentry:** define `SENTRY_DSN`. El código ya reporta todos los errores con `captureException` (Hecho en el código); sin DSN solo quedan en los registros de Vercel.
- **Monitor externo de disponibilidad** (por ejemplo UptimeRobot o Better Stack, planes gratis) sobre el login, el micrositio de un certamen y una ruta de estado, con aviso al celular. Es lo que te avisa si el sistema cae a las 3 de la mañana.

- **Alertas operativas** del propio ERP: folios del SII por agotarse y turno de caja (Hecho en el código). Revisa que lleguen.
- **Página de estado** sencilla para tus clientes: reduce llamadas cuando hay un incidente.

3.5 RespalDOS y continuidad

- **Dos capas.** (1) Restauración de Neon, para errores recientes. (2) Exportación completa por empresa en JSON (/api/backup/company, Hecho en el código): guárdala mensualmente fuera de la plataforma.
- **Esa exportación no es una restauración:** sirve para portabilidad y archivo. Para recuperarte de un desastre depende de Neon, así que la prueba de restauración es obligatoria.
- **Copia de archivos.** Habilita versionado o una copia periódica del bucket de R2 si la pérdida de contratos o certificados sería grave.
- **Plan de incidente escrito:** quién avisa a los clientes, cómo se hace rollback, quién tiene acceso a Neon, Vercel y Cloudflare. Con 2 personas con acceso de administrador, no una.

4. Qué vigilar al seguir escalando

Señal	Qué significa	Qué hacer
Primera consulta de la mañana lenta	El cómputo de Neon se suspendió por inactividad.	Activa cómputo siempre disponible (Launch) o sube el mínimo de CU.
Errores "too many connections"	Demasiadas instancias abriendo conexiones.	Confirma la URL pooled; baja max si hace falta.
Cuentas de CU-horas subiendo mes a mes	Más uso o consultas ineficientes.	Revisa consultas lentas y agrega índices. Optimiza Radiografía 360 y reportes.
Picos en noches de gala	Votación pública y venta de entradas concentradas en minutos.	Prueba de carga antes del evento; sube el mínimo de CU esa semana; deja Cloudflare con caché en páginas públicas estáticas.
Backup o afiches que superan el tiempo	Funciones limitadas a 300 s y 60 s.	Escalona los backups por empresa; ejecuta los pesados fuera de horario.
Costo de Vercel por encima del crédito	Uso de funciones o ancho de banda.	Revisa qué rutas consumen más; cachea en Cloudflare lo público.
Folios del SII por agotarse	Sin folios no se pueden emitir DTE timbrados.	Atiende la alerta operativa; pide un nuevo CAF con anticipación.
Quejas de tiempos distintos entre usuarios	Datos de una empresa muy grande frente a las demás.	Paginación y filtros por fecha en listados; índices por companyId + fecha.

Etapas recomendadas

Etapas	Qué hacer
1 a 10 empresas	Vercel Pro + Neon Launch. Rama de desarrollo de Neon. Cloudflare conectado. R2 y bucket privado. Sentry y monitor externo. Backup mensual descargado.
10 a 25 empresas	Revisión mensual de consultas lentas y costos. Límite de gasto en Vercel y Neon. Prueba de restauración trimestral. Segunda persona con acceso administrativo.
25 a 50 empresas	Prueba de carga antes de cada evento grande. Evalúa Cloudflare Pro. Escalona los cron pesados. Revisa si la caja a 13 semanas y la Radiografía 360 siguen rápidas con el volumen real.
Más de 50 o clientes exigentes	Evalúa Neon Scale (SLA, IP allow), un contrato de soporte, rate limit compartido (Redis/Upstash) en lugar del limitador por instancia y un entorno de staging dedicado.

5. El certificado médico: qué se corrigió y qué falta que hagas tú

Qué había. Los documentos de candidata (certificado médico, contratos) se guardaban en un bucket con URL pública. El nombre del archivo es impredecible y la app los muestra por una ruta con sesión, pero quien obtuviera la URL podía abrirlo sin sesión.

Qué cambió en el código.

- Nuevo almacenamiento privado (putPrivate en src/lib/storage/blob.ts): sube a un bucket de R2 sin URL pública y guarda una referencia interna r2private:///... que no se puede abrir desde fuera.
- La subida de documentos de candidata (/api/candidates/document-upload) usa ese almacenamiento.
- La ruta de descarga /api/candidates/[id]/documents/[docId]/file lee el archivo con las credenciales del servidor, exige el permiso candidates:sensitive y deja registro de cada descarga.
- Los borrados, la validación de la empresa en la ruta del archivo y el filtro contra SSRF también entienden la referencia privada.
- Tests nuevos (tests/storage-private.test.ts). Typecheck, lint y los tests de subida pasan.

- Hallazgo: la ruta pública de postulación ya no recibe archivos (solo texto), así que el certificado médico solo entra por el panel.

Qué debes hacer tú (el código solo no basta):

- En Cloudflare, R2: crea un **segundo bucket** (por ejemplo aether-privado) **sin acceso público y sin dominio conectado**.
- Dale al mismo token de API permiso de lectura y escritura sobre ese bucket.
- En Vercel agrega R2_PRIVATE_BUCKET_NAME en Production y vuelve a desplegar.
- **Hasta que lo hagas**, los archivos nuevos se siguen subiendo con URL pública (con una advertencia en los registros). Es deliberado, para no romper la subida.
- **Archivos anteriores:** los ya subidos siguen en el bucket público. Si ya hay certificados reales, hay que moverlos al bucket privado y actualizar su referencia en la base; puedo hacerte ese script de migración (conviene correrlo primero en la rama de desarrollo de Neon).

6. Riesgos conocidos del proyecto

Riesgo	Detalle	Prioridad
Base compartida con producción	El .env local apunta a la base de producción. Un script o migración de prueba toca datos reales.	Alta. Se resuelve con una rama de Neon.
Firma y envío al SII	La firma XML-DSig con certificado digital, el envío al SII y el Consumo de Folios aún no están implementados. Hoy el documento se timbra pero ese paso se hace fuera del sistema.	Alta si vendes emisión tributaria como servicio completo; dilo claramente al cliente.
Limitador de peticiones en memoria	Cada instancia lleva sus contadores. Un ataque distribuido entre instancias no los comparte.	Media. Se mitiga con las reglas de Cloudflare.
Archivos antiguos en almacenamiento público	Anteriores al cambio de hoy.	Media. Migrar tras crear el bucket privado.
Persona única con acceso	Si solo tú tienes accesos a Neon, Vercel y Cloudflare, una ausencia es una caída.	Media. Agrega un segundo administrador.
Archivos sueltos en la raíz del repositorio	Exportaciones .xlsx de empresa de prueba, imágenes y logs (hallazgo CF-06).	Baja. Confirmar y retirar.

7. Rutina de mantenimiento

Frecuencia	Revisión
Cada semana	Errores nuevos en Sentry. Cron ejecutados en Vercel. Alertas de folios del SII. Uso de cómputo en Neon.
Cada mes	Costo real de Neon, Vercel, R2 y Gemini contra lo estimado. Consultas lentas. Descargar la exportación completa de cada empresa. Revisar accesos y usuarios inactivos. Actualizar dependencias y revisar avisos de seguridad.
Cada trimestre	Probar la restauración de Neon en una rama. Probar el rollback de Vercel. Revisar reglas de WAF y falsos positivos. Repasar el plan de incidentes.
Antes de cada evento grande	Prueba de carga de votación y entradas. Subir el mínimo de CU esa semana. Avisar a Cloudflare y Vercel si esperas un pico muy grande. Tener a alguien disponible esa noche.
Antes de cada despliegue	Ejecutar npm run ci (valida Prisma, tipos, lint y tests). Revisar el SQL de migraciones nuevas. Probar en Preview.

Siguientes pasos que recomiendo, en orden. 1) Crear el bucket privado y la variable de R2. 2) Crear la rama de desarrollo de Neon y dejar de usar la base de producción en local. 3) Terminar la conexión con Cloudflare y el bloqueo de origen. 4) Activar Sentry y un monitor de disponibilidad. 5) Ensayar una restauración. 6) Pagar Vercel Pro antes del primer cliente de pago, y Neon Launch antes de guardar datos reales.